WALKER PRESS

CompTIA Security+ SY0-701

Practice Exam 5 of 5

90 Questions | 90 Minutes | Passing score 750 on a scale of 100–900

• This practice exam mirrors the format of the CompTIA Security+ SY0-701 certification exam: a maximum of 90 questions in 90 minutes.
• CompTIA reports the passing score as 750 on a scale of 100 to 900. That scale is CompTIA's own and is not a percentage of correct answers, so this document does not print a pass mark of its own. Use the Answer Key to find the objectives that need another evening.
• Questions are weighted by domain as on the real exam: General Security Concepts 12%, Threats, Vulnerabilities, and Mitigations 22%, Security Architecture 18%, Security Operations 28%, Security Program Management and Oversight 20%.
• Question types include Multiple Choice, Select Two/Three and Matching. For Matching questions, pair each item with the best description.
• The Answer Key with a full explanation for every question is at the end of this document.

www.walker-press.com

Questions

Question 1 [Multiple Choice]

Ada is researching DDoS mitigations for her company. Which of the following should Ada consider?

- **A.** A DDoS mitigation and traffic-scrubbing service
- **B.** A DNS sinkhole for known-malicious domain queries
- **C.** A MAC address pit filter appliance
- **D.** An IP denier gateway appliance

Question 2 [Matching]

Identify the control type that each measure below illustrates.

Items	Descriptions
1. Encrypting a database before it is stored	**A.** Compensating: an alternative used when a primary control is not feasible
2. A posted warning that the site is under 24/7 video monitoring	**B.** Physical: protects the tangible environment with barriers
3. Reviewing SIEM logs for anomalies	**C.** Preventive: stops an incident before it occurs
4. Restoring servers from backup after ransomware	**D.** Deterrent: discourages a would-be attacker
5. An acceptable use policy directing employee behavior	**E.** Corrective: restores normal operation after an incident
	F. Detective: identifies an incident after it occurs
	G. Directive: instructs or mandates required behavior

Question 3 [Multiple Choice]

Which vulnerability type allows attackers to execute malicious code in the context of a web browser?

- **A.** Command injection
- **B.** Session hijacking
- **C.** SQL injection
- **D.** Cross-site scripting (XSS)

Question 4 [Multiple Choice]

Astri is reviewing a log file of a new firewall. She notes that the log indicates packets are being dropped for incoming packets for which the internal endpoint did not initially create the request. What kind of firewall is this?

- **A.** Stateful packet-filtering firewall
- **B.** Stateless packet-filtering firewall
- **C.** Proxy firewall
- **D.** Application-layer firewall

Question 5 [Multiple Choice]

Emma is reading the documentation for the new UPS that just arrived. Which of the following will the new UPS NOT perform?

A. Prevent selected applications from launching based on their power consumption
B. Provide temporary battery power during an outage
C. Send power-failure and low-battery alerts through UPS management software
D. Signal a connected server to begin a graceful shutdown through UPS management software

Question 6 [Multiple Choice]

Fill in the blank: A _____ is a documented agreement that outlines performance expectations between two organizations.

A. NDA
B. SLA
C. MOU
D. BPA

Question 7 [Multiple Choice]

The CEO is frustrated by the high costs associated with security at the organization and wants to look at a third party assuming part of their cybersecurity defenses. Emeric has been asked to look into acquiring requests for proposals (RFPs) from different third parties. What are these third-party organizations called?

A. MXIAs
B. MSSOs
C. MPSs
D. MSSPs

Question 8 [Multiple Choice]

What is the purpose of a write blocker during forensic investigations?

A. Disconnect endpoints from cloud
B. Isolate wireless interfaces
C. Prevent modification of original data
D. Log attacker keystrokes

Question 9 [Multiple Choice]

A company receives a report from an external vendor that their website is vulnerable to a known CVE. What is the best initial step?

A. Conduct a broad vulnerability scan of the entire environment
B. Perform a penetration test
C. Accept the risk and log it
D. Review the affected system and patch if verified

Question 10 [Matching]

Match each encryption method with its characteristic.

Items	Descriptions
1. Symmetric encryption	**A.** Uses two keys: public and private
2. Asymmetric encryption	**B.** Replaces sensitive values with placeholders
3. Hashing	**C.** Uses the same key for encryption and decryption
4. Tokenization	**D.** Converts data into irreversible fixed-length value

Question 11 [Multiple Choice]

Which of the following is considered a physical control?

- **A.** MAC address filtering on access points
- **B.** Security event log monitoring and review
- **C.** Smart card-controlled door access
- **D.** Site-to-site VPN tunnel

Question 12 [Multiple Choice]

What does risk transference involve?

- **A.** Outsourcing risk to a third party like an insurer
- **B.** Ignoring low-impact threats without documenting them
- **C.** Deleting the sensitive data and retiring the system
- **D.** Accepting all known risks without any mitigation

Question 13 [Multiple Choice]

Which authentication method uses multiple attributes like location, device, and time to allow access?

- **A.** Context-aware authentication
- **B.** MFA
- **C.** Biometric login
- **D.** Federation

Question 14 [Multiple Choice]

Which of the following types of computer viruses is malicious computer code that becomes part of a file?

- **A.** File-based virus
- **B.** Jump virus
- **C.** Fileless virus
- **D.** RAM-Check virus

Question 15 [Multiple Choice]

Which technique is used by attackers to trick users into installing malware through legitimate- looking software updates?

- **A.** Drive-by download
- **B.** Malvertising
- **C.** Typosquatting
- **D.** Fake update attack

Question 16 [Multiple Choice]

Which option describes a proactive defensive practice in which analysts search for previously undetected adversary activity?

- **A.** Machine learning
- **B.** Security operations center (SOC)
- **C.** Threat hunting
- **D.** Data analytics

Question 17 [Multiple Choice]

Which of the following involves the automation and combination of many different tasks and processes?

- **A.** Autoflow
- **B.** Cybersecurity automation
- **C.** Multitask combination (MTC)
- **D.** Orchestration

Question 18 [Matching]

Match each backup strategy with its recovery priority.

Items	Descriptions
1. Full	**A.** Fastest restore; largest storage
2. Incremental	**B.** Moderate speed, larger files
3. Differential	**C.** Requires all backups in sequence
4. Snapshot	**D.** Instant rollback at a point in time

Question 19 [Multiple Choice]

Which of the following best describes the concept of integrity in the CIA triad?

- **A.** Making sure systems are always online
- **B.** Ensuring only authorized users can access data
- **C.** Encrypting all traffic on a network
- **D.** Ensuring data is not altered without authorization

Question 20 [Multiple Choice]

Which regulation is MOST concerned with the handling of healthcare information in the U.S.?

- **A.** CCPA
- **B.** SOX
- **C.** GDPR
- **D.** HIPAA

Question 21 [Multiple Choice]

An administrator schedules a firewall firmware upgrade for Sunday between 2 a.m. and 4 a.m., when almost no users are online, to limit the effect of the required service restart. Which change-management concept does this scheduling represent?

- **A.** Maintenance window
- **B.** Version control
- **C.** Impact analysis
- **D.** Backout plan

Question 22 [Multiple Choice]

Fill in the blank: _____ is the overall attack in which DNS poisoning or hosts-file modification redirects a user who entered the correct URL to a fraudulent replica of a legitimate website.

A. Pharming
B. Typosquatting
C. DNS spoofing
D. Phishing

Question 23 [Multiple Choice]

Which of the following does NOT apply to a vulnerability scan?

A. Identify vulnerabilities by scanning systems and networks
B. Report discovered weaknesses with severity ratings so administrators can prioritize remediation
C. Use primarily automated checks with some manual validation
D. Simulate adversarial exploitation to determine whether vulnerabilities are exploitable

Question 24 [Multiple Choice]

What is the most appropriate method to ensure that logs are not tampered with after collection?

A. Compress them using gzip
B. Archive them on the same host
C. Forward them to a syslog server
D. Digitally sign or hash them

Question 25 [Multiple Choice]

JSON and XML would be classified as which type of data?

A. Regulated data
B. Non-human-readable data
C. Encrypted data
D. Human-readable data

Question 26 [Multiple Choice]

An organization has a low risk appetite. What action will they MOST LIKELY take?

A. Accept all low-impact risks
B. Disable redundant logging
C. Increase data retention times
D. Implement strict access controls

Question 27 [Multiple Choice]

In an SDN architecture, what is a primary function of the control plane?

A. Forward packets using installed forwarding rules
B. Handle email delivery
C. Make routing and policy decisions and program network devices
D. Back up endpoints

Question 28 [Multiple Choice]

What does an organization gain from performing regular tabletop exercises?

A. Full restoration of encrypted files
B. Elimination of audit trails
C. Improved incident response coordination
D. Higher network speed

Question 29 [Multiple Choice]

Which activity is associated with security awareness practices rather than third-party risk assessment and management?

A. Obtaining an independent vendor assessment
B. Reviewing a right-to-audit clause
C. Supply chain analysis
D. User guidance and training

Question 30 [Multiple Choice]

What is the difference between a keylogger and spyware?

A. A keylogger operates much faster than spyware.
B. Spyware is illegal while a keylogger is not.
C. A keylogger captures keystrokes, while spyware is a broader user-monitoring category.
D. Spyware can be installed using an inline hardware device, while a keylogger exists only as software.

Question 31 [Multiple Choice]

Danylo is examining the results of a vulnerability scan and is prioritizing the list of vulnerabilities. He wants to use a system that will assign a numeric score to each vulnerability. Which system will Danylo use?

A. RDV
B. CRV
C. VDSS
D. CVSS

Question 32 [Multiple Choice]

Which type of memory vulnerability attack manipulates the "return address" of the memory location of a software program?

A. Stuffing attack
B. Integer overwrite
C. Pointer attack
D. Buffer overflow attack

Question 33 [Multiple Choice]

Which of the following is sometimes called a "network virus" because it enters a computer to move through the network?

A. Fileless virus
B. File-based virus
C. Worm
D. Trojan

Question 34 [Multiple Choice]

Fill in the blank: _____ is the process of identifying and documenting weaknesses that could be exploited.

A. Vulnerability assessment
B. SQL injection
C. Zero-day exploit
D. Social engineering

Question 35 [Multiple Choice]

Which standard enables federated single sign-on by exchanging authentication assertions between an identity provider and multiple service providers?

A. MDM
B. LDAP
C. SIEM
D. SAML

Question 36 [Multiple Choice]

Which of the following is most helpful in minimizing the impact of credential theft?

A. Multifactor authentication
B. User training
C. Vulnerability scan
D. Password vault

Question 37 [Matching]

A company's incident response team is writing a digital forensics procedure for incidents that may lead to litigation. Match each forensic term to its description.

Items	Descriptions
1. Legal hold	**A.** Creating a verified forensic image or memory capture from the affected system
2. Chain of custody	**B.** Protecting collected evidence from alteration, for example with write blockers and hash verification
3. Acquisition	**C.** Identifying, collecting, and producing electronically stored information requested for a legal proceeding
4. E-discovery	**D.** Formal notice that relevant records must be retained and not deleted because litigation is anticipated
5. Preservation	**E.** Determining the underlying reason an incident occurred so that it does not recur
	F. Documented record of every person who handled the evidence, when, and for what purpose
	G. Proactively searching logs and telemetry for adversary activity that automated alerts missed

Question 38 [Multiple Choice]

What is the difference between data masking and tokenization?

A. Masking destroys the original values, while tokenization encrypts them in place
B. They are identical in function and interchangeable
C. Tokenization uses real values; masking uses hashes
D. Masking obfuscates data on display; tokenization replaces data with a reference

Question 39 [Multiple Choice]

What is a common use case for conducting tabletop exercises?

A. Detonating live malware samples against production endpoints
B. Practicing coordinated response to simulated incidents
C. Calibrating biometric authentication thresholds
D. Stress-testing the network perimeter with load tools

Question 40 [Multiple Choice]

What does a privacy impact assessment (PIA) help organizations evaluate?

A. Resource scalability in hybrid cloud
B. Incident handling capabilities
C. Data collection practices and privacy risks
D. Hardware lifespan

Question 41 [Multiple Choice]

Angelo has received a document that is part of a contract that describes the work requirements for a specific project. What type of document is this?

A. SOW
B. EOS
C. EOA
D. BPP

Question 42 [Multiple Choice]

A user receives an unsolicited email containing a link to a fake password-reset page designed to steal login credentials. Which email-based social engineering attack is this?

A. Pretexting
B. Phishing
C. Whaling
D. Vishing

Question 43 [Multiple Choice]

Scenario: After investigating a breach, the team documents all actions taken and identifies areas for improvement. Which phase is this?

A. Containment
B. Eradication
C. Lessons learned
D. Recovery

Question 44 [Multiple Choice]

A security team receives multiple alerts from a SIEM platform. What should be the first step?

A. Notify all end users about the pending alerts
B. Run a full backup of the affected systems
C. Triage the alerts for prioritization
D. Immediately shut down the entire corporate network

Question 45 [Multiple Choice]

Which of the following is NOT a feature of blocking (screen-locking) ransomware?

A. It displays a ransom message that may impersonate a trusted organization or authority.
B. It prevents the user from operating the device normally.
C. It can reliably be removed by power-cycling the device twice.
D. It locks access to the device interface rather than primarily encrypting user files.

Question 46 [Multiple Choice]

Which type of wireless attack captures traffic in the hope of cracking encryption offline?

A. Packet sniffing
B. Replay
C. Evil twin
D. Deauthentication

Question 47 [Multiple Choice]

What does the detection phase of incident response involve?

A. Applying firewall rules
B. Removing infected files and other malware artifacts
C. Preventing user access to compromised accounts and hosts
D. Identifying potential indicators of compromise

Question 48 [Select Two]

A SOC's entire phishing-response workflow is a single script on one server, written by an engineer who has since left. Nobody else understands the code, it still calls an API version the vendor deprecated, and when the server was rebooted last week no phishing reports were processed for a day. Which TWO automation considerations does this situation illustrate? (Select TWO.)

A. Standard infrastructure configurations
B. Reaction time
C. Technical debt
D. Workforce multiplier
E. Single point of failure

Question 49 [Multiple Choice]

Which of the following approaches to risk calculation typically assigns a numeric value (1–10) or label (High, Medium, or Low) to represent a risk?

A. Qualitative
B. Rule based
C. Quantitative
D. Policy based

Question 50 [Multiple Choice]

A digital signature provides which two core security functions?

- **A.** Confidentiality and redundancy
- **B.** Availability and federation
- **C.** Encryption and hashing
- **D.** Authentication and integrity

Question 51 [Multiple Choice]

What tool would most help identify file changes on a suspected compromised workstation?

- **A.** DNS sinkhole redirection
- **B.** File integrity monitoring (FIM)
- **C.** Network intrusion detection system (NIDS)
- **D.** Security information and event management (SIEM)

Question 52 [Matching]

Match each framework or standard to its focus.

Items	Descriptions
1. PCI DSS	**A.** Technical controls for federal systems
2. HIPAA	**B.** Global ISMS management
3. ISO/IEC 27001	**C.** Payment card industry security
4. NIST SP 800-53	**D.** Healthcare data protection

Question 53 [Multiple Choice]

Fill in the blank: A _____ is a predefined plan that outlines actions to take during a specific type of security incident.

- **A.** Threat hunting
- **B.** Playbook execution
- **C.** EDR containment
- **D.** Playbook

Question 54 [Select Two]

An organization wants cryptographic keys generated and stored inside dedicated, tamper-resistant hardware rather than in software. Which TWO technologies meet this requirement? (Select TWO.)

- **A.** Self-signed certificate
- **B.** Certificate revocation list (CRL)
- **C.** Hardware security module (HSM)
- **D.** Online Certificate Status Protocol (OCSP)
- **E.** Trusted Platform Module (TPM)

Question 55 [Multiple Choice]

Which network appliance provides administrators with a controlled, hardened intermediary system for accessing devices in a protected security zone?

- **A.** Passive sensor
- **B.** Jump server
- **C.** Web application firewall
- **D.** Load balancer

Question 56 [Multiple Choice]

Which of the following statements is NOT true about a pressure sensor?

A. A pressure sensor can detect pressure caused by a person or vehicle
B. Multiple pressure sensors can be arranged to help determine movement direction
C. A pressure sensor is a type of managerial control
D. A pressure sensor can help detect entry into a restricted area

Question 57 [Multiple Choice]

What is the PRIMARY goal of a red team assessment?

A. Audit software license usage
B. Identify business process inefficiencies
C. Monitor system uptime
D. Emulate attacker behavior to test defenses

Question 58 [Multiple Choice]

Which of the following is the most effective control against brute-force password attacks?

A. Port scanning
B. Remote wipe capability
C. Account lockout policy
D. DNS sinkholing

Question 59 [Multiple Choice]

Tobias received an SMS text message that falsely said his bank account was overdrawn and, to avoid a $45 fee, he should contact the bank immediately with an explanation. What type of social engineering attack is this?

A. Smishing
B. Email phishing
C. Business email compromise
D. Vishing

Question 60 [Multiple Choice]

In a Zero Trust deployment, one control-plane component receives the access decision from the policy engine and then sets up or tears down the session by signaling the enforcement point. Which component performs this role?

A. Policy Engine
B. Policy Administrator
C. Implicit trust zone
D. Policy Enforcement Point

Question 61 [Multiple Choice]

Fill in the blank: _____ defines how long it should take to restore systems after a failure.

A. RTO (Recovery Time Objective)
B. RPO (Recovery Point Objective)
C. MTTR (Mean Time To Repair)
D. MTBF (Mean Time Between Failures)

Question 62 [Select Two]

A company is evaluating a payroll SaaS provider that will process employee bank details. The procurement team wants independent evidence of the vendor's security posture before signing. Which TWO items provide this evidence? (Select TWO.)

A. The results of a recent penetration test performed against the vendor by an outside firm
B. An independent third-party audit report covering the vendor's security controls
C. A self-assessment questionnaire completed by the vendor's sales team without supporting documents
D. A master service agreement defining the general terms of the relationship
E. The vendor's published marketing brochure describing its security features

Question 63 [Matching]

Match each security objective to its corresponding CIA triad element.

Note: the same description may apply to more than one item.

Items	Descriptions
1. Preventing unauthorized data disclosure	**A.** Confidentiality
2. Ensuring systems are accessible during business hours	**B.** Availability
3. Verifying that audit logs haven't been altered	**C.** Integrity
4. Encrypting sensitive data stored on company laptops	

Question 64 [Multiple Choice]

Gabe is creating a report for his supervisor Cora that outlines the total risk that the organization can bear in a given risk profile. Which of the following terms would Gabe be using?

A. Risk appetite
B. Risk expansion
C. Risk acceptance
D. Risk tolerance

Question 65 [Multiple Choice]

Which governance structure has ultimate oversight responsibility for approving an organization's strategic goals and high-level policies?

A. Committee
B. Board
C. Council
D. Panel

Question 66 [Multiple Choice]

What is another name for runtime verification?

A. Static code analysis
B. Fuzzering
C. Weighted code analysis
D. Dynamic code analysis

Question 67 [Multiple Choice]

Bracha is completing a request for proposal (RFP) to be sent to different vendors. The RFP mandates 99.9999999% annual uptime. What availability level should Bracha specify?

A. Six Nines
B. Nine Nines
C. Five Nines
D. Three Nines

Question 68 [Multiple Choice]

Which of the following do plug-ins NOT contain?

A. Remediation actions
B. Listing of vulnerable local IP addresses
C. Updated algorithms
D. Advanced vulnerability information

Question 69 [Multiple Choice]

Which of the following is typically handled by front-end components rather than by backend microservices?

A. Database
B. Authentication
C. User experience (UX)
D. Logs

Question 70 [Matching]

Match each log type to its MOST characteristic content. Each description is used exactly once.

Items	Descriptions
1. Application log	**A.** Kernel messages and hardware status
2. System log	**B.** Program-specific errors and events
3. Security log	**C.** Login failures and policy violations
4. Audit log	**D.** User access and changes

Question 71 [Multiple Choice]

Fill in the blank: A _____ attack exploits a vulnerability in how software handles unexpected input, often crashing or executing code.

A. Brute force
B. Zero-day exploit
C. Buffer overflow
D. Man-in-the-middle

Question 72 [Multiple Choice]

A data center needs to stop a vehicle from being driven through the main lobby entrance while still letting pedestrians walk in freely. Which physical security control best meets this need?

A. Bollards
B. Video surveillance
C. Access badge
D. Access control vestibule

Question 73 [Multiple Choice]

Which of the following is NOT true about RATs?

A. A RAT can give a threat actor unauthorized remote access through a command-and-control channel.
B. A RAT and a worm have the same basic function.
C. A RAT can let an attacker monitor activity, modify settings, browse or copy files, and potentially access other networked systems.
D. A RAT creates a remote-access channel whose capabilities depend on the malware and the compromised user's privileges.

Question 74 [Multiple Choice]

What is a list of potential threats and associated risks called?

A. Risk register
B. Risk matrix
C. Risk assessment
D. Risk portfolio

Question 75 [Multiple Choice]

A helpdesk technician receives a call from someone who falsely claims to be the CEO and urgently requests password changes. Which social-engineering technique describes the caller's false claim of identity, rather than the voice-call delivery vector?

A. Vishing
B. Impersonation
C. Shoulder surfing
D. Dumpster diving

Question 76 [Multiple Choice]

Which type of user should normally receive standard nonadministrative permissions for performing routine business tasks in a production environment?

A. Developer
B. Root user
C. Service account
D. End user

Question 77 [Multiple Choice]

Which of the following access control models uses predefined rules and labels to enforce policies?

A. DAC
B. MAC
C. ABAC
D. RBAC

Question 78 [Multiple Choice]

Which document should outline how long an organization retains email communications?

A. Risk register
B. AUP
C. Data retention policy
D. SLA

Question 79 [Multiple Choice]

Fill in the blank: _____ ensures that a user cannot deny having performed an action.

- **A.** Tokenization
- **B.** VPN tunnel
- **C.** Encryption
- **D.** Non-repudiation

Question 80 [Matching]

Match each identity-related concept with its function.

Items	Descriptions
1. Provisioning	**A.** Logging into multiple systems with one credential
2. Deprovisioning	**B.** Terminating user access after departure
3. SSO	**C.** Authenticating across domains or organizations
4. Federation	**D.** Granting user access and roles at onboarding

Question 81 [Multiple Choice]

Which of the following is voluntary and not mandatory?

- **A.** Standard
- **B.** Procedure
- **C.** Policy
- **D.** Guideline

Question 82 [Multiple Choice]

What is a key sign of a logic bomb in a compromised system?

- **A.** It disables antivirus protection immediately on infection
- **B.** It replicates itself and spreads through email attachments
- **C.** It encrypts every attached drive the moment it executes
- **D.** It activates only after a specific condition is met

Question 83 [Multiple Choice]

Fill in the blank: _____ logs would be most useful for identifying a brute-force login attempt.

- **A.** Encryption
- **B.** Authorization
- **C.** Authentication logs
- **D.** Accounting

Question 84 [Multiple Choice]

Which device intercepts internal user requests and then processes those requests on behalf of the users?

- **A.** Reverse proxy server
- **B.** Forward proxy server
- **C.** Host detection server
- **D.** Intrusion prevention device

Question 85 [Multiple Choice]

Which of the following is a key benefit of patch management?

A. Fixes known vulnerabilities
B. Increases bandwidth
C. Obfuscates software versions
D. Reduces log sizes

Question 86 [Multiple Choice]

Fill in the blank: The _____ principle ensures a system continues to provide access to resources when needed.

A. Integrity
B. Accountability
C. Availability
D. Confidentiality

Question 87 [Multiple Choice]

A company hosts public services in a DMZ. Which of the following should be the next best control to protect internal resources?

A. Use stateful firewalls between DMZ and internal networks
B. Configure a load balancer in front of the DMZ web server pool
C. Implement failover routing between redundant edge router pairs
D. Enable NAT traversal for inbound and outbound application sessions

Question 88 [Select Two]

Select TWO methods to help prevent SQL injection attacks:

A. Code obfuscation
B. Application load balancing
C. Input sanitization
D. Server redundancy
E. Use of prepared statements

Question 89 [Multiple Choice]

A file hash does which of the following?

A. Ensures integrity by generating a unique fingerprint
B. Encrypts the file's contents with a symmetric encryption key
C. Conceals the file's contents from unauthorized viewers
D. Obfuscates the file's metadata fields from indexing tools

Question 90 [Multiple Choice]

Which DNS attack would only impact a single user?

A. DNS hijack attack
B. DNS poisoning attack
C. DNS overflow attack
D. DNS resource attack

Answer Key

Each answer is followed by the reasoning behind it, including why the other options fall short.

Q1: A

A. A DDoS mitigation and traffic-scrubbing service is correct. Dedicated DDoS mitigation (on-premises appliances or cloud scrubbing providers) absorbs and filters volumetric, protocol, and application-layer attack traffic before it reaches the target, which is exactly what Ada is researching. B. A DNS sinkhole for known-malicious domain queries is incorrect. A DNS sinkhole answers queries for known-bad domains with a controlled address so that malware cannot reach its command-and-control server; it blocks outbound malicious name resolution and does nothing to absorb inbound attack traffic aimed at Ada's services. C. A MAC address pit filter appliance is incorrect: it is not a real security technology, the term is a distractor. D. An IP denier gateway appliance is incorrect: it is likewise not a recognized security control.

Q2: 1 = C; 2 = D; 3 = F; 4 = E; 5 = G

1 → C (Preventive): encrypting a database before storage stops unauthorized disclosure before it can happen. 2 → D (Deterrent): a posted warning of 24/7 video monitoring discourages a would-be attacker without physically stopping anyone. 3 → F (Detective): reviewing SIEM logs identifies suspicious activity after it has occurred. 4 → E (Corrective): restoring servers from backup returns operations to normal after a ransomware incident. 5 → G (Directive): an acceptable use policy mandates how employees must behave. Unused: A (Compensating) — no alternative-for-a-missing-control example is shown; B (Physical) — this set names control types by function, and no tangible barrier is listed.

Q3: D

C. SQL injection is incorrect. SQLi injects malicious database queries to read or alter back-end data on the server; it does not run script in the victim's browser. D. Cross-site scripting (XSS) is correct. XSS injects malicious script into a web page so that it executes in the context of another user's browser, enabling actions such as session token theft or content manipulation. A. Command injection is incorrect. Command injection runs operating-system commands on the server hosting the application, not code inside the browser. B. Session hijacking is incorrect. Session hijacking steals or reuses a valid session token to impersonate a user; it is not the execution of code within the browser.

Q4: A

A. Stateful packet-filtering firewall is correct: it maintains a connection state table and drops incoming packets that do not belong to a connection initiated by an internal endpoint, which is exactly the behavior Astri sees in the log. D. Application-layer firewall is incorrect because it filters based on application-level content and protocol commands, not on whether an internal endpoint initiated the connection. C. Proxy firewall is incorrect because it terminates and re-establishes connections on behalf of clients; the log describes state-based dropping, not proxied sessions. B. Stateless packet-filtering firewall is incorrect because it evaluates each packet in isolation against static rules and cannot know whether the internal endpoint originally created the request.

Q5: A

A. Prevent selected applications from launching based on their power consumption is the correct answer: a UPS supplies and manages power, and neither the unit nor its management software controls which applications are allowed to start. B. Provide temporary battery power during an outage is not the answer because battery backup is the core function of every UPS. D. Signal a connected server to begin a graceful shutdown is not the answer because UPS management software commonly initiates orderly shutdowns when battery reserve runs low. C. Send power-failure and low-battery alerts is not the answer because notifications are a standard feature of UPS management software.

Q6: B

C. MOU is incorrect. A Memorandum of Understanding is a non-binding, high-level statement of intent between parties and does not define measurable performance metrics. B. SLA is correct. A Service Level Agreement is a formal, documented contract that specifies measurable performance expectations such as uptime, response time, and remediation timelines between a provider and a customer. A. NDA is incorrect. A Non-Disclosure Agreement protects confidentiality of shared information; it does not define service performance. D. BPA is incorrect. A Business Partnership Agreement outlines ownership, profit-sharing, and responsibilities between partners, not performance metrics between organizations.

Q7: D

A. MXIAs is incorrect because it is not a recognized type of provider. C. MPSs is incorrect because it is not the term for an outsourced security provider. D. MSSPs is correct because Managed Security Service Providers are the third parties that deliver outsourced monitoring and management of an organization's security systems, which is what the CEO wants to procure. B. MSSOs is incorrect because it is not an established term.

Q8: C

B. Isolate wireless interfaces is incorrect. Disabling radios can prevent remote wiping of a seized device, but that is not the function of a write blocker. D. Log attacker keystrokes is incorrect. Keystroke capture is a monitoring or keylogging function, unrelated to forensic imaging. C. Prevent modification of original data is correct. A write blocker sits between the investigator's system and the source media and permits reads while blocking any writes, preserving the integrity of the original evidence so the acquisition is forensically sound. A. Disconnect endpoints from cloud is incorrect. Severing cloud connectivity is a containment action, not the role of a write blocker.

Q9: D

C. Accept the risk and log it is incorrect. Accepting a documented, known vulnerability without validation is negligent when a fix may be available. A. Conduct a broad vulnerability scan of the entire environment is incorrect. An environment-wide scan is slower and less focused than confirming the specific reported CVE on the affected asset. B. Perform a penetration test is incorrect. A pen test is a larger engagement; it is disproportionate as an immediate first step when a specific CVE is already reported. D. Review the affected system and patch if verified is correct. The appropriate first step is to confirm whether the reported CVE actually applies to the organization’s configuration and version, then remediate via patching or compensating controls.

Q10: 1 = C; 2 = A; 3 = D; 4 = B

Symmetric encryption matches "Uses the same key for encryption and decryption" because algorithms like AES use one shared secret for both operations, enabling fast bulk encryption. Asymmetric encryption matches "Uses two keys: public and private" since schemes like RSA or ECC rely on a mathematically linked key pair where one key encrypts and the other decrypts. Hashing matches "Converts data into irreversible fixed-length value" because algorithms such as SHA-256 produce a one-way digest used for integrity rather than confidentiality. Tokenization matches "Replaces sensitive values with placeholders" since tokens are random substitutes stored alongside a secure mapping to the original data, protecting the real value from exposure.

Q11: C

B. Security event log monitoring and review is incorrect. Reviewing logs is a technical, detective control implemented in software, not a physical safeguard. C. Smart card-controlled door access is correct. A smart card reader that gates bodily entry through a door is a physical control; the tangible badge and reader are the enforcement mechanism. D. Site-to-site VPN tunnel is incorrect. A VPN is a technical control that encrypts network traffic between sites; it has no physical component. A. MAC address filtering on access points is incorrect. Filtering by MAC address is a technical network control configured in software on switches or wireless access points.

Q12: A

A (Outsourcing risk to a third party like an insurer) is correct: transference shifts the financial impact of a risk onto another party through cyber insurance or a contract with a service provider, even though accountability for the data usually stays with the organisation. D (Accepting all known risks without any mitigation) is incorrect because that is risk acceptance, where the organisation knowingly carries the impact itself. B (Ignoring low-impact threats without documenting them) is incorrect because ignoring a risk is informal acceptance at best and hands nothing to a third party. C (Deleting the sensitive data and retiring the system) is incorrect because removing the asset altogether is risk avoidance: the exposure is eliminated rather than transferred to someone else.

Q13: A

B. MFA is incorrect. Multifactor authentication combines factors from different categories (something you know, have, or are); it is not defined by contextual attributes such as location, device, and time. D. Federation is incorrect. Federation lets one organization trust identities issued by another so users can log in across domains; it does not evaluate contextual attributes to grant access. A. Context-aware authentication is correct. This approach evaluates contextual signals such as location, device posture, and time of day to make an adaptive, risk-based access decision. C. Biometric login is incorrect. Biometrics is a single 'something you are' factor and does not weigh location, device, and time.

Q14: A

A. Correct — a file-based virus is malicious code that attaches to or becomes part of a legitimate file, infecting it and spreading to other files when the host file is executed. B. "Jump virus" is not a recognized category of computer virus. C. A fileless virus resides in memory and abuses legitimate tools rather than becoming part of a file on disk, so it does not match the description. D. "RAM-Check virus" is not a real virus type; it is a fabricated term.

Q15: D

A. Drive-by download is incorrect. A drive-by download infects a visitor automatically through a compromised or malicious web page, without presenting a fake update prompt or requiring the user to run an installer. C. Typosquatting is incorrect. Typosquatting registers lookalike domain names to catch users who mistype an address; it is not the delivery of a fake update. B. Malvertising is incorrect. Malvertising delivers malicious code through online advertisements; while it can redirect users, it is not specifically the fake-update lure described here. D. Fake update attack is correct. Attackers present a bogus software or browser update prompt so the victim voluntarily downloads and installs the malicious payload, believing it is a legitimate update.

Q16: C

C. Threat hunting is correct — it is the proactive practice in which analysts form hypotheses and actively search systems, logs, and data for adversary activity that automated controls have not detected. A. Machine learning is incorrect — it is an analytical technique that can support detection, not a defensive practice in itself. D. Data analytics is incorrect — analyzing data is a general capability, not the named proactive search for undetected intrusions. B. Security operations center (SOC) is incorrect — a SOC is the organizational team and facility where monitoring and hunting take place, not the practice itself.

Q17: D

D (Orchestration) is correct: orchestration is the coordination of many separate automated tasks and processes so that they run together as a single workflow. In security operations this is what SOAR platforms deliver: they ingest alerts, run playbooks, and chain actions such as IP blocking, user isolation, and ticket creation across multiple tools. C (Multitask combination (MTC)) is incorrect because it is not a recognized Security+ term for combining automated processes. B (Cybersecurity automation) is incorrect because automation refers to a single task being performed without human intervention, such as a script that blocks an IP address; orchestration is the higher-level combining of many such tasks. A (Autoflow) is incorrect because it is not a standard security operations term; the objectives describe the combination of automated tasks as orchestration.

Q18: 1 = A; 2 = C; 3 = B; 4 = D

The correct mapping is: Full backup offers the fastest restore time because all data is contained in a single backup set, but it requires the most storage and takes the longest to complete. Incremental backup requires all backups in sequence — the last full plus every incremental since — meaning restore requires assembling many files but each backup is small and fast. Differential backup has moderate speed and larger file sizes because it captures everything changed since the last full backup, requiring only two backup sets to restore. Snapshot provides instant rollback to a specific point in time, typically used in virtualized environments for near-instant recovery.

Q19: D

B. Ensuring only authorized users can access data is incorrect. This describes confidentiality — the 'C' in CIA — which focuses on restricting information access to authorized parties. A. Making sure systems are always online is incorrect. This describes availability — the 'A' in CIA — which ensures resources are accessible when needed. D. Ensuring data is not altered without authorization is correct. Integrity guarantees that data remains accurate and unmodified except through authorized processes, often verified using hashing or digital signatures. C. Encrypting all traffic on a network is incorrect. Encryption supports confidentiality but is not itself the definition of integrity in the CIA triad.

Q20: D

C. GDPR is incorrect. The General Data Protection Regulation governs personal data protection and privacy for individuals in the European Union, not U.S. healthcare data specifically. D. HIPAA is correct. The Health Insurance Portability and Accountability Act is the U.S. regulation that sets requirements for safeguarding protected health information (PHI) held by healthcare providers, plans, and their business associates. B. SOX is incorrect. The Sarbanes-Oxley Act governs financial reporting and corporate accountability for U.S. public companies, not healthcare information. A. CCPA is incorrect. The California Consumer Privacy Act addresses consumer privacy rights for California residents broadly; it is not the regulation specifically concerned with healthcare information.

Q21: A

A is correct (Maintenance window): a maintenance window is a pre-approved period chosen to minimize disruption while a change and any service restart are performed. D is incorrect (Backout plan): a backout plan is the rollback procedure used if the change fails, not the timing of the work. C is incorrect (Impact analysis): impact analysis assesses risk and consequences beforehand but does not schedule the work. B is incorrect (Version control): version control tracks changes to files and configurations over time and is unrelated to choosing a low-traffic time slot.

Q22: A

D. Phishing is incorrect because it is a social-engineering attack that lures victims with deceptive messages; it does not describe redirecting a correctly typed URL through DNS or hosts-file manipulation. C. DNS spoofing is incorrect because it names the underlying technique of corrupting name resolution, not the overall user-facing attack described in the stem. A. Pharming is correct: it is the overall attack in which DNS poisoning or hosts-file modification sends a user who typed the legitimate URL to a fraudulent replica of the site. B. Typosquatting is incorrect because it relies on the attacker registering misspelled domains and the user mistyping the address, not on manipulating name resolution.

Q23: D

A. Identifying vulnerabilities by scanning systems and networks applies - it is the core function of a vulnerability scan. B. Reporting discovered weaknesses with severity ratings so administrators can prioritize remediation applies - scan output is ranked by severity (commonly with CVSS scores) and feeds the remediation workflow. C. Using primarily automated checks with some manual validation applies - scans are largely automated with limited manual review to weed out false positives. D. Simulating adversarial exploitation to determine whether vulnerabilities are exploitable is the exception: actively exploiting weaknesses like a threat actor characterizes penetration testing, not vulnerability scanning.

Q24: D

A. Compress them using gzip is incorrect. Compression saves storage but does nothing to detect or prevent modification of the log contents. C. Forward them to a syslog server is incorrect. Centralizing logs helps, but a syslog server does not by itself prove the records were not altered in transit or after arrival unless integrity protection is added. D. Digitally sign or hash them is correct. Computing a cryptographic hash or digital signature over each log or batch lets you detect any later modification, because altered data produces a different hash; signing also proves origin. This is the standard way to guarantee log integrity. B. Archive them on the same host is incorrect. Keeping logs on the originating host leaves them within reach of an attacker who compromises that host and can edit or delete them.

Q25: D

C. Encrypted data is incorrect. JSON and XML are plaintext formats; encryption is a protection that may be applied to data, not a property of these formats themselves. D. Human-readable data is correct. JSON and XML are text-based formats that a person can open and interpret directly, which places them in the human-readable category of data types. A. Regulated data is incorrect. Regulated data is defined by the legal obligations attached to its content, such as health or payment data, not by the file format used to store it. B. Non-human-readable data is incorrect. Non-human-readable data, such as binary files or compiled code, cannot be directly interpreted by a person, unlike JSON and XML.

Q26: D

A. Accept all low-impact risks is incorrect. Broad acceptance of risk is characteristic of a high (expansionary) risk appetite, the opposite of a conservative posture. D. Implement strict access controls is correct. A low risk appetite means the organization tolerates little risk, so it applies stronger mitigations, such as tight access controls, least privilege, and layered defenses, to drive residual risk down. C. Increase data retention times is incorrect. Retaining more data typically increases exposure and liability, which raises rather than reduces risk. B. Disable redundant logging is incorrect. Removing logging weakens detection and forensic capability, increasing risk, the wrong move for a risk-averse organization.

Q27: C

C. Make routing and policy decisions and program network devices is correct. In software-defined networking the control plane is centralized in the controller: it computes routes, defines security and traffic policies, and pushes the resulting forwarding rules down to switches and routers. A. Forward packets using installed forwarding rules is incorrect — executing already-installed rules on live traffic is the data plane's job. B. Handle email delivery is incorrect — mail delivery is an application-layer service provided by mail servers, unrelated to network planes. D. Back up endpoints is incorrect — endpoint backup is a data-protection task handled by backup software, not a function of any network plane.

Q28: C

D. Higher network speed is incorrect. A tabletop exercise is a discussion-based walkthrough of a scenario; it has no effect on network throughput. B. Elimination of audit trails is incorrect. Audit trails are retained for accountability and investigation; a tabletop exercise would never aim to remove them. C. Improved incident response coordination is correct. In a tabletop exercise, stakeholders talk through their roles and decisions against a simulated incident, exposing gaps in the plan and improving how teams communicate and coordinate before a real event occurs. A. Full restoration of encrypted files is incorrect. Restoring files is an operational recovery task performed from backups, not an outcome of a discussion-based exercise.

Q29: D

C. Supply chain analysis is incorrect. It is a vendor assessment activity within third-party risk management, used to evaluate the risks a vendor inherits from its own suppliers. B. Reviewing a right-to-audit clause is incorrect. The right-to-audit clause is a contractual vendor assessment mechanism that lets an organization inspect a third party's practices. D. User guidance and training is correct. It belongs to security awareness practices aimed at the organization's own users, not to the assessment or management of third-party risk. A. Obtaining an independent vendor assessment is incorrect. Independent assessments are a standard vendor assessment method in third-party risk management.

Q30: C

A. Speed is incorrect: execution speed is not what distinguishes a keylogger from spyware. B. Legality is incorrect: both are malicious when installed without consent, so legality does not define the difference. C. Correct: a keylogger is narrowly focused on capturing keystrokes, while spyware is a broader surveillance category that can monitor browsing, screen content, or file access and may itself include keylogging functionality. D. Hardware installation is incorrect, and in fact reversed: keyloggers are the ones that also exist as physical inline devices placed between a keyboard and a host, while spyware is software.

Q31: D

B. CRV is incorrect because it is not a vulnerability scoring system. C. VDSS is incorrect because it is not a recognized scoring standard. A. RDV is incorrect because it is not a real scoring framework. D. CVSS is correct because the Common Vulnerability Scoring System assigns each vulnerability a numeric severity score, which teams use to prioritize remediation.

Q32: D

D (Buffer overflow attack) is correct: a buffer overflow occurs when a program writes more data into a memory buffer than it can hold, so the excess spills into adjacent memory. On the stack, the adjacent area contains the function's return address, and an attacker overwrites it so that when the function finishes, execution jumps to the attacker's code. C (Pointer attack) is incorrect because a pointer or object dereference attack manipulates a pointer to reference an unexpected memory location; it does not overflow a buffer into the return address. A (Stuffing attack) is incorrect because credential stuffing is an authentication attack that replays stolen username and password pairs. B (Integer overwrite) is incorrect because the related memory flaw is an integer overflow, which produces an unexpectedly wrapped value in a calculation, not a rewritten return address.

Q33: C

C (Worm) is correct: a worm is malware that self-replicates and spreads on its own from one computer to another across a network, exploiting vulnerabilities without needing a user to run a file. Because its defining behavior is entering a system and then moving through the network, it is sometimes called a network virus. A (Fileless virus) is incorrect because fileless malware runs in memory and abuses legitimate tools such as PowerShell to evade detection; its distinguishing trait is the absence of a file on disk, not network propagation. D (Trojan) is incorrect because a Trojan disguises itself as a legitimate program to trick the user into installing it and does not replicate or travel across the network by itself. B (File-based virus) is incorrect because a traditional virus attaches itself to a file and needs a user action to execute and spread rather than moving independently.

Q34: A

D. Social engineering is incorrect. Social engineering manipulates people through psychological tactics to reveal information or perform actions — it is an attack category, not a process for identifying technical weaknesses. B. SQL injection is incorrect. SQL injection is a specific exploit technique targeting database query logic — not a systematic process for cataloguing security weaknesses. A. Vulnerability assessment is correct. A vulnerability assessment is the structured process of identifying, quantifying, and documenting security weaknesses in systems, applications, and configurations using automated scanners and manual techniques — before attackers can exploit them. C. Zero-day exploit is incorrect. A zero-day exploit targets a previously unknown vulnerability for which no patch exists — it is an attack type used against unassessed weaknesses, not the assessment process itself.

Q35: D

A. MDM is incorrect. Mobile device management enforces configuration and security policy on mobile endpoints; it does not exchange authentication assertions between an identity provider and services. B. LDAP is incorrect. LDAP is a protocol for querying and authenticating against a central directory service; it is not a federation standard that passes assertions from an identity provider to service providers. D. SAML is correct. Security Assertion Markup Language exchanges XML-based authentication and authorization assertions between an identity provider and service providers, enabling federated single sign-on across multiple services. C. SIEM is incorrect. A SIEM aggregates and correlates security event logs for monitoring and alerting; it plays no role in authenticating users.

Q36: A

B. User training is incorrect. Security awareness training helps users avoid disclosing credentials, but if a password is still stolen, training alone does nothing to stop the attacker from using it. D. Password vault is incorrect. A password vault helps store and generate strong, unique passwords, reducing reuse, but once a specific credential is captured the vault does not block its use elsewhere. A. Multifactor authentication is correct. Even when a password is stolen, MFA requires an additional factor (something you have or something you are) that the attacker does not possess, so the stolen credential alone cannot grant access - directly minimizing the impact of credential theft. C. Vulnerability scan is incorrect. A vulnerability scan identifies weaknesses in systems; it neither prevents credential theft nor limits what an attacker can do with a stolen password.

Q37: 1 = D; 2 = F; 3 = A; 4 = C; 5 = B

1 → D (Formal notice that relevant records must be retained and not deleted because litigation is anticipated): a legal hold suspends normal deletion and retention schedules as soon as litigation is reasonably anticipated. 2 → F (Documented record of every person who handled the evidence, when, and for what purpose): the chain of custody proves the evidence was never left unaccounted for, which keeps it admissible. 3 → A (Creating a verified forensic image or memory capture from the affected system): acquisition is the collection step, performed in order of volatility and validated with hashes. 4 → C (Identifying, collecting, and producing electronically stored information requested for a legal proceeding): e-discovery is the legal process of producing electronically stored information for a case and is broader than forensic analysis. 5 → B (Protecting collected evidence from alteration, for example with write blockers and hash verification): preservation keeps evidence in its original state throughout the investigation. Unused: G (Proactively searching logs and telemetry for adversary activity that automated alerts missed) — that is threat hunting, an operations activity rather than a forensic step; E (Determining the underlying reason an incident occurred so that it does not recur) — that is root cause analysis, performed during lessons learned.

Q38: D

A. Masking destroys the original values, while tokenization encrypts them in place is incorrect. It misstates both techniques: masking never destroys the source data - it hides or substitutes values in what is presented or in a copy, leaving the original record available - and tokenization does not encrypt the field in place, it swaps in a surrogate value. C. Tokenization uses real values; masking uses hashes is incorrect. Tokenization specifically avoids exposing real values by swapping in a token, and masking obscures characters (for example, showing only the last four digits) rather than hashing them. D. Masking obfuscates data on display; tokenization replaces data with a reference is correct. Data masking hides or scrambles values as they are shown while the underlying data is unchanged, whereas tokenization replaces a sensitive value with a surrogate token that maps back to the original only through a secure token vault. B. They are identical in function and interchangeable is incorrect. They are distinct techniques with different mechanisms and use cases.

Q39: B

B (Practicing coordinated response to simulated incidents) is correct: a tabletop exercise is a discussion-based walkthrough in which responders talk through a hypothetical scenario, testing roles, decision points and the playbook and exposing gaps without touching production. A (Detonating live malware samples against production endpoints) is incorrect because a tabletop executes nothing; running real malware would be a live-fire or red team activity. D (Stress-testing the network perimeter with load tools) is incorrect because that is hands-on technical testing performed with tooling, not a discussion. C (Calibrating biometric authentication thresholds) is incorrect because tuning false acceptance and rejection rates is a device configuration task unrelated to rehearsing an incident.

Q40: C

B. Incident handling capabilities is incorrect: those are evaluated through incident response planning and testing, not a PIA. D. Hardware lifespan is incorrect: it relates to asset management, not privacy analysis. C. Data collection practices and privacy risks is correct: a privacy impact assessment analyzes what personal data is collected, how it is used and stored, and the privacy risks involved. A. Resource scalability in hybrid cloud is incorrect: that is an architecture/capacity concern, unrelated to a PIA.

Q41: A

A (SOW) is correct: a statement of work (SOW), also issued as a work order (WO), is the contractual document that spells out the specific work to be performed for a project, including deliverables, timelines, milestones, and acceptance criteria. It typically sits under a broader master service agreement (MSA) and turns the general relationship into a concrete assignment, which matches the document Angelo received. C (EOA) is incorrect because it is not a recognized Security+ agreement type; no standard contract document uses this abbreviation. D (BPP) is incorrect because it is not a contract or agreement term in the SY0-701 objectives; the closest real term is the business partners agreement (BPA). B (EOS) is incorrect because it usually stands for end of support or end of service, a product lifecycle milestone, not a document describing work requirements.

Q42: B

C. Whaling is incorrect because nothing indicates the recipient is a high-level executive singled out for their role. A. Pretexting is incorrect because it centers on a fabricated scenario or impersonated identity used to extract information or action, typically in an interactive exchange; here the defining mechanism is a deceptive email link to a credential-harvesting page. B. Phishing is correct: an unsolicited deceptive email that lures the user to a fake password-reset page to steal login credentials is a classic phishing attack. D. Vishing is incorrect because it is carried out over voice calls, not email.

Q43: C

A. Containment is incorrect. Containment limits the spread of an active incident and happens during the response, not after it. B. Eradication is incorrect. Eradication removes the cause from the environment; it precedes recovery and is still part of handling the incident. D. Recovery is incorrect. Recovery restores systems to normal operation and validates that they are clean; documenting and reviewing comes after it. C. Lessons learned is correct. The lessons learned phase, also called post-incident review, takes place once the incident is resolved: responders record what happened, what worked and what failed, and the improvements identified feed back into preparation.

Q44: C

A. Notify all end users about the pending alerts is incorrect. Notifying users is premature before understanding which alerts are genuine threats versus false positives. D. Immediately shut down the entire corporate network is incorrect. A blanket network shutdown would cause widespread disruption and is disproportionate before alert severity has been assessed. C. Triage the alerts for prioritization is correct. Triage involves evaluating all alerts by severity, credibility, and potential impact to determine which require immediate action, preventing analysts from wasting time on low-priority or false-positive alerts while real threats go unaddressed. B. Run a full backup of the affected systems is incorrect. Backups are a recovery action, not an initial response to incoming alerts.

Q45: C

A. Displaying a ransom message that may impersonate a trusted organization or authority is a genuine feature of blocking ransomware, so it is not the correct choice. B. Preventing the user from operating the device normally is the core behavior of blocking ransomware, so it is not the correct choice. C. Correct — blocking ransomware cannot reliably be removed by power-cycling the device: it persists across reboots and re-locks the screen, so this is NOT one of its features. D. Locking access to the device interface rather than primarily encrypting user files is the defining characteristic of blocking (screen-locking) ransomware, so it is not the correct choice.

Q46: A

C. Evil twin is incorrect. An evil twin is a rogue access point that impersonates a legitimate one to lure clients; it intercepts sessions live rather than capturing ciphertext for later offline cracking. B. Replay is incorrect. A replay attack retransmits previously captured frames to gain access in real time; it does not describe collecting traffic to crack encryption offline. D. Deauthentication is incorrect. A deauth attack forces clients off the network (often to disrupt service or trigger a handshake); by itself it is a disruption technique, not the capture-and-crack action described. A. Packet sniffing is correct. Passively capturing wireless frames — for example the WPA handshake — lets an attacker take the captured data away and attempt to crack the encryption key offline through brute-force or dictionary attacks.

Q47: D

D (Identifying potential indicators of compromise) is correct: detection is the phase where monitoring and alerting turn raw events into a validated incident, so analysts hunt for and confirm IoCs such as anomalous logins, beaconing traffic or known-bad file hashes. C (Preventing user access to compromised accounts and hosts) is incorrect because cutting off accounts or hosts is a containment action taken after an incident is confirmed. B (Removing infected files and other malware artifacts) is incorrect because deleting malware and its artefacts is eradication, which follows containment. A (Applying firewall rules) is incorrect because blocking traffic is a containment or mitigation step, not the act of discovering the incident.

Q48: C, E

E and C are correct: running the whole workflow through one script on one server means any outage stops the process entirely, which is a single point of failure, and undocumented code that depends on a deprecated API and that no current employee can maintain is technical debt that grows more expensive and riskier over time. D is incorrect (Workforce multiplier) because that is a benefit of automation, letting a small team handle more work, not a risk shown here. B is incorrect (Reaction time) because faster response is another benefit of automation, whereas this scenario shows the workflow failing rather than responding quickly. A is incorrect (Standard infrastructure configurations) because it describes automation being used to enforce consistent builds, which is a benefit and is unrelated to an unmaintained script.

Q49: A

A (Qualitative) is correct: qualitative risk analysis rates each risk using descriptive scales rather than precise measurements, such as a 1 to 10 score or labels like High, Medium, and Low, often plotted on a risk matrix or heat map. It relies on expert judgment and is quick to communicate, which is why the question's numeric-or-label approach describes it. C (Quantitative) is incorrect because quantitative analysis assigns concrete monetary or statistical values, such as asset value, exposure factor, SLE, ARO, and ALE, instead of rankings or labels. B (Rule based) is incorrect because it is not a risk calculation approach; the term is associated with access control and detection signatures. D (Policy based) is incorrect because it is likewise not a method of calculating risk; policies set the requirements that risk assessments help enforce, not an analysis technique.

Q50: D

C. Encryption and hashing is incorrect. Encryption and hashing are techniques a signature may use internally, not the security services it delivers; a signature does not provide confidentiality of the message. D. Authentication and integrity is correct. A digital signature is created by encrypting a hash of the message with the signer's private key. Verifying it with the signer's public key proves who signed it (authentication, and by extension non-repudiation) and confirms the content has not changed since signing (integrity). A. Confidentiality and redundancy is incorrect. A digital signature does not conceal the message contents (no confidentiality) and has nothing to do with duplicating components (redundancy). B. Availability and federation is incorrect. Signatures do not keep systems available, and federation is an identity-sharing model unrelated to signing.

Q51: B

D. Security information and event management (SIEM) is incorrect. A SIEM aggregates and correlates logs from many sources network-wide. While it can surface file-change events if the relevant logs are forwarded to it, it is not the primary dedicated tool for detecting host-level file modifications. B. File integrity monitoring (FIM) is correct. FIM tools (such as Tripwire or OSSEC) create cryptographic hashes of critical files and directories at baseline, then continuously compare current state against that baseline. Any modification, deletion, or new file creation triggers an alert - making FIM the most direct tool for detecting unauthorized changes on a potentially compromised workstation. A. DNS sinkhole redirection is incorrect. A DNS sinkhole redirects malicious domain queries to a controlled IP address for blocking and analysis - it has no visibility into the host file system. C. Network intrusion detection system (NIDS) is incorrect. A NIDS monitors network traffic for malicious patterns; it cannot inspect the file system of individual endpoints.

Q52: 1 = C; 2 = D; 3 = B; 4 = A

PCI DSS matches "Payment card industry security" because it defines the controls required for any entity storing, processing, or transmitting cardholder data. HIPAA matches "Healthcare data protection" as the U.S. regulation that mandates safeguards for Protected Health Information held by covered entities and business associates. ISO/IEC 27001 matches "Global ISMS management," giving international requirements to implement and certify an Information Security Management System. NIST SP 800-53 matches "Technical controls for federal systems," providing a comprehensive control catalog used by U.S. federal agencies and contractors to meet FISMA obligations.

Q53: D

B. Playbook execution is incorrect. "Execution" is the act of running a plan, not the plan itself; the question asks for the predefined plan's name. D. Playbook is correct. In incident response and SOAR workflows, a playbook is a documented, step-by-step plan that defines exactly what actions to take for a specific incident type (e.g., phishing, ransomware). A. Threat hunting is incorrect. Threat hunting is the proactive search for undetected adversaries, not a predefined response plan. C. EDR containment is incorrect. This describes a specific technical action an EDR tool may take, not the overall incident response document.

Q54: C, E

E and C are correct: a TPM is a tamper-resistant chip on a device that generates and protects keys, and an HSM is a dedicated tamper-resistant appliance that generates, stores, and uses keys, so both keep key material in hardware. B is incorrect: a CRL is a published list of revoked certificates, not a key-storage device. D is incorrect: OCSP is a protocol for checking a certificate's revocation status in real time, not hardware. A is incorrect: a self-signed certificate is signed by its own creator and stores no keys in tamper-resistant hardware.

Q55: B

B. Jump server is correct. A jump server is a hardened host that administrators connect through to reach systems in a protected zone, concentrating privileged access in a single controlled and monitored point. D. Load balancer is incorrect. A load balancer distributes client requests across multiple servers for availability and performance; it is not an administrative access path. C. Web application firewall is incorrect. A WAF inspects HTTP/HTTPS traffic to protect web applications; it does not provide administrators with access to protected systems. A. Passive sensor is incorrect. A passive sensor only monitors copies of network traffic for analysis; it does not sit in any access path and cannot serve as an intermediary.

Q56: C

A. "A pressure sensor can detect pressure caused by a person or vehicle" is a true statement, so it is not the correct choice: pressure sensors trigger on the weight or force applied to them, whether from a person or a vehicle. B. "Multiple pressure sensors can be arranged to help determine movement direction" is a true statement, so it is not the correct choice: the order in which the sensors trigger reveals the direction of travel. C. "A pressure sensor is a type of managerial control" is the correct answer because it is NOT true: a pressure sensor is a physical control that detects intrusion, while managerial controls are policies, procedures, and oversight processes. D. "A pressure sensor can help detect entry into a restricted area" is a true statement, so it is not the correct choice: placing sensors at entry points detects unauthorized access to the area.

Q57: D

A. Audit software license usage is incorrect. License auditing is an IT asset management function — it has no relationship to offensive security testing or defense evaluation. B. Identify business process inefficiencies is incorrect. Business process improvement is an operations management function, not the goal of a red team security engagement. D. Emulate attacker behavior to test defenses is correct. A red team assessment uses the same tactics, techniques, and procedures (TTPs) as real adversaries — including social engineering, exploitation, and lateral movement — to test whether defenses, detection capabilities, and incident response are effective under realistic attack conditions. C. Monitor system uptime is incorrect. Uptime monitoring is a NOC (Network Operations Center) function using availability dashboards, not a red team activity.

Q58: C

A. Port scanning is incorrect. Port scanning enumerates open services; it does nothing to stop repeated password guessing. C. Account lockout policy is correct. Locking an account after a set number of failed login attempts directly defeats brute-force password attacks by preventing the attacker from continuing to try passwords. D. DNS sinkholing is incorrect. DNS sinkholing redirects traffic destined for known-malicious domains and is unrelated to defending against password guessing. B. Remote wipe capability is incorrect. Remote wipe erases data on a lost or stolen device; it does not prevent brute-force attempts against an account.

Q59: A

D. Vishing is incorrect because it uses voice calls rather than text messages. B. Email phishing is incorrect because the fraudulent message reached Tobias by SMS, not by email. A. Smishing is correct: it is phishing carried out over SMS text messages, exactly matching the fraudulent bank text Tobias received. C. Business email compromise is incorrect because it involves compromised or spoofed business email accounts used to defraud an organization, not an SMS sent to an individual.

Q60: B

B is correct (Policy Administrator): the policy administrator acts on the policy engine's decision, generating or revoking session credentials and instructing the enforcement point to allow or block the path. A is incorrect (Policy Engine): the policy engine evaluates identity, device posture, and context to make the decision, but it does not carry the decision out. D is incorrect (Policy Enforcement Point): the PEP sits in the data plane and actually permits or denies the traffic, enforcing rather than administering the decision. C is incorrect (Implicit trust zone): an implicit trust zone is an area trusted after a request passes a PEP, not a decision-making component.

Q61: A

A (RTO (Recovery Time Objective)) is correct: the recovery time objective is the maximum acceptable amount of time a system, application, or function can remain down after a disruption, so it defines how quickly restoration must be completed. An RTO of one hour for a payment system means recovery plans must restore it within that hour. B (RPO (Recovery Point Objective)) is incorrect because the RPO measures acceptable data loss in time, that is, how far back the last usable backup may be, not how long recovery takes. D (MTBF (Mean Time Between Failures)) is incorrect because MTBF is a reliability metric predicting the average operating time between one failure and the next. C (MTTR (Mean Time To Repair)) is incorrect because MTTR is the historical average time actually taken to repair a failed component, whereas the RTO is the target set by the business impact analysis.

Q62: A, B

B and A are correct: an independent audit report reflects an outside assessor's testing of the vendor's controls, and an external penetration test shows whether those controls withstand attack; both come from parties other than the vendor's own staff, which makes them independent evidence. C is incorrect (unsupported self-assessment questionnaire) because questionnaires help with scoping, but unsupported self-reported answers are neither independent nor verified. E is incorrect (marketing brochure) because marketing material is promotional and unverified. D is incorrect (master service agreement) because an MSA sets contract terms such as liability and termination; it documents obligations, not evidence that the vendor's controls work.

Q63: 1 = A; 2 = B; 3 = C; 4 = A

Correct pairings: Preventing unauthorized data disclosure = Confidentiality; Ensuring systems are accessible during business hours = Availability; Verifying that audit logs haven't been altered = Integrity; Encrypting sensitive data stored on company laptops = Confidentiality. Confidentiality covers any objective that keeps data readable only by authorized parties: both the general goal of preventing disclosure and the specific mechanism of encrypting data at rest fall under this pillar, which is why two items map to it by design. Availability concerns keeping systems and data accessible when needed, which is what business-hours accessibility describes. Integrity ensures information has not been improperly altered; verifying that audit logs are unchanged (for example through hashing or write-once storage) is an integrity check.

Q64: A

A (Risk appetite) is correct: risk appetite is the strategic level of risk an organization is prepared to accept in pursuit of its objectives, defined by the board or executives. Because Gabe's report describes the total risk the organization can bear within a given risk profile, he is describing appetite, which can be expansionary, neutral, or conservative. D (Risk tolerance) is incorrect because tolerance is the acceptable variation within the appetite, an operational threshold set at the department or team level, rather than the overall amount of risk the organization will carry. B (Risk expansion) is incorrect because it is not a risk management term; expansionary is merely one type of risk appetite. C (Risk acceptance) is incorrect because acceptance is one of the four risk responses applied to an individual risk, not a measure of the organization's total capacity for risk.

Q65: B

D. Panel is incorrect: a panel is a group convened to advise on or evaluate a specific matter and holds no ultimate oversight authority. A. Committee is incorrect: committees operate under authority delegated by the board and focus on specific areas such as audit or risk. B. Board is correct: the board of directors holds ultimate oversight responsibility and approves the organization's strategic goals and high-level policies. C. Council is incorrect: a council is an advisory or coordinating body and is not the structure with final approval authority over organizational strategy.

Q66: D

D (Dynamic code analysis) is correct: dynamic analysis, also called runtime verification, tests an application while it is actually executing, observing its behavior, memory use, inputs, and outputs to find flaws that only appear at run time. Because it verifies the running program rather than the source, the two names describe the same technique. A (Static code analysis) is incorrect because static analysis examines the source code or binary without running it, so it is the opposite of runtime verification. B (Fuzzering) is incorrect because the real technique is called fuzzing, and although fuzzing is one dynamic testing method that feeds random or malformed input to a running program, it is a specific test rather than a synonym for runtime verification. C (Weighted code analysis) is incorrect because it is not a recognized application testing method.

Q67: B

C. Five Nines is incorrect. 99.999% uptime allows roughly 5.26 minutes of downtime per year, far more than the mandated 99.9999999%. B. Nine Nines is correct. 99.9999999% uptime corresponds to nine nines of availability, allowing only about 31.5 milliseconds of downtime per year. A. Six Nines is incorrect. 99.9999% uptime allows roughly 31.5 seconds of downtime per year, which does not meet the mandated level. D. Three Nines is incorrect. 99.9% uptime allows almost 8.8 hours of downtime per year, well below the requirement.

Q68: B

D. Advanced vulnerability information is incorrect as the answer because plug-ins do carry detailed information about the specific vulnerabilities they check for. B. Listing of vulnerable local IP addresses is correct because it is what plug-ins do NOT contain: which of your hosts are vulnerable is discovered when the scan runs against your environment, not shipped inside the plug-in. A. Remediation actions is incorrect as the answer because plug-ins commonly include guidance on how to fix the issues they detect. C. Updated algorithms is incorrect as the answer because plug-ins are updated with the current detection logic used to test for vulnerabilities.

Q69: C

C. User experience (UX) is correct. The user experience is implemented by front-end/UI components and design teams; backend microservices expose functionality through APIs but do not render or manage the UX. A. Database is incorrect. In a microservices architecture each service typically owns and manages its own data store, which is a backend concern. D. Logs is incorrect. Microservices generate and manage their own logs on the backend for monitoring and troubleshooting. B. Authentication is incorrect. Authentication is enforced on the backend — by the services themselves or delegated to a backend identity provider or API gateway — not by front-end components.

Q70: 1 = B; 2 = A; 3 = C; 4 = D

The correct mapping is: Application log records program-specific errors and events — crashes, exceptions, transaction failures, and application-level warnings generated by software. System log captures kernel messages and hardware status — OS-level events, driver errors, boot sequences, and resource utilization. Security log records login failures and policy violations — authentication attempts, access denials, and security-relevant events used for breach detection and compliance auditing. Audit log tracks user access and changes — who accessed what resource, when, and what actions were taken, providing the accountability trail needed for forensic investigations and compliance reviews.

Q71: C

B. Zero-day exploit is incorrect. A zero-day refers to a vulnerability unknown to the vendor; it describes disclosure timing, not the mechanism of mishandling input. D. Man-in-the-middle is incorrect. MITM attacks intercept or relay traffic between two parties and are unrelated to memory corruption. C. Buffer overflow is correct. A buffer overflow exploits poor bounds checking by writing more data into a buffer than it can hold, overwriting adjacent memory and potentially crashing the program or executing attacker-supplied code. A. Brute force is incorrect. Brute force systematically tries credentials or keys; it does not involve unexpected input handling flaws.

Q72: A

A is correct (Bollards): bollards are short, sturdy posts placed to block vehicles from entering an area while leaving room for people to pass on foot. D is incorrect (Access control vestibule): a vestibule controls how many people move through a doorway to stop tailgating; it does not stop vehicles. B is incorrect (Video surveillance): cameras record and deter but cannot physically stop a moving vehicle. C is incorrect (Access badge): a badge authenticates a person at a door and has no effect on a vehicle threat.

Q73: B

A. A RAT does give a threat actor unauthorized remote access through a command-and-control channel, so this statement is true and not the correct choice. B. Correct — this statement is NOT true: a worm's basic function is to self-replicate and spread across systems, while a RAT's basic function is to provide covert remote access and control; they are fundamentally different. C. RATs commonly let an attacker monitor activity, change settings, browse or copy files, and pivot to other networked systems, so this statement is true and not the correct choice. D. A RAT's remote-access capabilities do depend on the malware's features and the compromised user's privileges, so this statement is true and not the correct choice.

Q74: A

A (Risk register) is correct: a risk register is the living document or system that catalogs all identified threats and their associated risks. Each entry typically records a risk ID, description, likelihood, impact, risk owner, key risk indicators, current status, treatment plan, and residual risk, which makes the register the central list the question describes. C (Risk assessment) is incorrect because an assessment is the process of evaluating the likelihood and impact of risks, not the list that stores them; its results are fed into the register. B (Risk matrix) is incorrect because a matrix, or heat map, is a visual grid that plots likelihood against impact to prioritize risks, not a comprehensive listing of threats. D (Risk portfolio) is incorrect because it is not a standard Security+ term for the document that tracks identified risks; the register is the recognized artifact.

Q75: B

B. Impersonation is correct: the question asks for the identity-deception technique, and falsely claiming to be the CEO is exactly that. C. Shoulder surfing is incorrect because it involves visually observing someone's screen or keypad. D. Dumpster diving is incorrect because it involves recovering information from discarded materials. A. Vishing is incorrect here because it names the voice-call delivery vector, which the stem explicitly excludes in favor of the identity-deception technique.

Q76: D

A. Developer is incorrect because developers hold elevated rights in development environments and reach production only through controlled change processes, not with a standard business-user profile. C. Service account is incorrect because service accounts are non-interactive identities scoped to run a specific application or scheduled task; they do not perform routine business work. B. Root user is incorrect because root or administrator is the highest-privilege account and is reserved for system administration, not daily tasks. D. End user is correct: following least privilege, ordinary end users doing day-to-day business tasks in production should operate with standard nonadministrative permissions.

Q77: B

A. DAC is incorrect. Discretionary Access Control lets the data owner decide who gets access, which is flexible but not rule-and-label based. B. MAC is correct. Mandatory Access Control uses system-enforced policies that rely on predefined rules and classification labels (e.g., Secret, Top Secret) attached to subjects and objects; users cannot override these decisions. D. RBAC is incorrect. Role-Based Access Control grants permissions based on job roles, not on rule-and-label logic. C. ABAC is incorrect. Attribute-Based Access Control evaluates attributes of users, resources, and environment at access time; it is rule-driven but not based on classification labels the way MAC is.

Q78: C

B. AUP is incorrect. An Acceptable Use Policy defines how employees may use organizational systems and data, not how long records are kept. D. SLA is incorrect. A Service Level Agreement specifies service performance metrics between two parties; it does not govern retention periods. C. Data retention policy is correct. A data retention policy defines how long different types of records, including email communications, must be stored before they are archived or disposed of, balancing legal, regulatory, and operational needs. A. Risk register is incorrect. A risk register lists identified risks and their treatments; it does not dictate retention schedules.

Q79: D

D. Non-repudiation is correct. Non-repudiation ensures that a user cannot credibly deny having performed an action. It is achieved through digital signatures, PKI-based authentication, and immutable audit logs with timestamps. When a user signs a transaction with their private key, only they possess that key — denial becomes computationally infeasible. C. Encryption is incorrect. Encryption protects the confidentiality of data by making it unreadable to unauthorized parties — it does not prevent a user from denying that they performed an action. A. Tokenization is incorrect. Tokenization replaces sensitive data values with non-sensitive placeholders (tokens) for data protection — it has no connection to proving or denying user actions. B. VPN tunnel is incorrect. A VPN tunnel provides encrypted, authenticated remote connectivity — while it authenticates the connection, it does not provide non-repudiation of specific user actions performed after connecting.

Q80: 1 = D; 2 = B; 3 = A; 4 = C

The correct pairings are: Provisioning = Granting user access and roles at onboarding; Deprovisioning = Terminating user access after departure; SSO = Logging into multiple systems with one credential; Federation = Authenticating across domains or organizations. Provisioning creates accounts and assigns appropriate permissions when a user joins. Deprovisioning ensures all access is removed when an employee leaves, preventing unauthorized use of former credentials. SSO allows one authenticated session to grant access to multiple applications, reducing password fatigue. Federation extends authentication trust across organizational boundaries, enabling a partner company's credentials to be accepted on your systems.

Q81: D

D (Guideline) is correct: a guideline is a recommendation or best-practice suggestion that helps people apply policies and standards sensibly, but following it is discretionary. Guidelines offer flexibility where a rigid rule would not fit every situation. C (Policy) is incorrect because a policy is a mandatory, high-level statement of management intent, such as an acceptable use policy, that every employee is required to follow. A (Standard) is incorrect because a standard is a mandatory rule that specifies exactly how a policy is met, for example minimum password length or an approved encryption algorithm. B (Procedure) is incorrect because a procedure is a mandatory step-by-step instruction for carrying out a task, such as an onboarding checklist or a change management playbook, and deviations from it are not permitted.

Q82: D

B. It replicates itself and spreads through email attachments is incorrect. Self-replication and email propagation describe a worm, not a logic bomb. A. It disables antivirus protection immediately on infection is incorrect. Immediate action is not characteristic of a logic bomb, which stays dormant and hidden until it is triggered. D. It activates only after a specific condition is met is correct. A logic bomb is malicious code that remains dormant until a defined trigger (a specific date, event, or condition) is met, at which point it executes its payload. C. It encrypts every attached drive the moment it executes is incorrect. Instant mass encryption describes ransomware behavior, not the delayed, condition-based trigger of a logic bomb.

Q83: C

B. Authorization is incorrect. Authorization logs record what an already-identified user was permitted to access; a brute-force attack is about repeated login attempts, which are recorded at authentication. D. Accounting is incorrect. Accounting logs track resource usage and actions during a session, not the succession of failed logon attempts that characterize brute forcing. C. Authentication logs are correct. Brute-force attempts appear as many failed logon events for an account in a short window; authentication logs capture these success/failure records, making the pattern visible. A. Encryption is incorrect. Encryption protects data confidentiality and is not a category of log that would reveal repeated login attempts.

Q84: B

D. Intrusion prevention device is incorrect. An IPS inspects traffic inline to detect and block malicious activity; it does not relay internal users' requests on their behalf. B. Forward proxy server is correct. A forward proxy intercepts requests from internal users and makes those requests to external resources on their behalf, commonly for content filtering and access control. A. Reverse proxy server is incorrect. D reverse proxy handles requests coming from external clients toward internal servers, the opposite direction from what is described. C. Host detection server is incorrect. 'Host detection server' is not a recognized network device for proxying user requests; it is a distractor.

Q85: A

D. Reduces log sizes is incorrect. Patching does not shrink log files; log management tools handle log volume. B. Increases bandwidth is incorrect. Patches have no bandwidth impact beyond the download itself. A. Fixes known vulnerabilities is correct. Patch management systematically deploys vendor updates that close identified security flaws, closing exploitable gaps before attackers can leverage them. C. Obfuscates software versions is incorrect. Hiding version banners is a security-through-obscurity tactic; patching removes the actual underlying vulnerability instead of hiding its presence.

Q86: C

C. Availability is correct. Availability is the CIA triad pillar that guarantees authorized users can access systems and data whenever required, through controls such as redundancy, fault tolerance, and capacity planning. D. Confidentiality is incorrect. Confidentiality restricts access to authorized parties and protects data disclosure, not uptime. A. Integrity is incorrect. Integrity ensures data is not altered without authorization; it does not guarantee access. B. Accountability is incorrect. Accountability ties actions to identities via logging and non-repudiation; it is a supporting principle, not the one guaranteeing access.

Q87: A

B. Configure a load balancer in front of the DMZ web server pool is incorrect. A load balancer distributes traffic for performance and availability - it does not enforce a security boundary between the DMZ and the internal network. A. Use stateful firewalls between DMZ and internal networks is correct. A stateful firewall inspects the full context of each connection (not just individual packets), allowing legitimate return traffic while blocking unsolicited inbound connections from the DMZ - the critical control for protecting internal resources from a potentially compromised DMZ. D. Enable NAT traversal for inbound and outbound application sessions is incorrect. NAT traversal facilitates connectivity through NAT devices and provides no security isolation between network zones. C. Implement failover routing between redundant edge router pairs is incorrect. Failover routing supports availability during link failures but does not enforce a security boundary between DMZ and internal networks.

Q88: C, E

C. Input sanitization is correct. Validating and cleaning user-supplied input removes or neutralizes the characters and query fragments an attacker would use to alter a SQL statement. A. Code obfuscation is incorrect. Obfuscation makes source code harder to read but does nothing to stop malicious input from reaching the database query. E. Use of prepared statements is correct. Parameterized (prepared) queries bind user input as data rather than executable SQL, so injected commands cannot change the query's structure — the primary defense against SQLi. D. Server redundancy is incorrect. Redundant servers improve availability; they provide no protection against injection. B. Application load balancing is incorrect. Load balancing distributes traffic for performance and availability and has no bearing on how database queries are constructed.

Q89: A

C. Conceals the file's contents from unauthorized viewers is incorrect. Hashing does not conceal data; it produces a fixed-length digest and cannot be reversed, so it neither hides nor reveals the original contents. A. Ensures integrity by generating a unique fingerprint is correct. A hash function produces a fixed-length digest that acts as a unique fingerprint of the file; if even one bit changes, the hash changes, so comparing hashes confirms whether the file has been altered. B. Encrypts the file's contents with a symmetric encryption key is incorrect. Encryption transforms data into reversible ciphertext using a key; hashing is one-way and uses no key, so it does not encrypt. D. Obfuscates the file's metadata fields from indexing tools is incorrect. Hashing neither targets nor obscures metadata; it computes a digest over the file's contents to verify integrity.

Q90: D

A DNS resource attack typically targets a specific user's DNS resources, affecting only that individual user's ability to resolve domain names correctly. Other DNS attacks usually have broader impacts on multiple users or entire networks.